

Digital - Staff SOE Hardening Standard

Contents

Contents.....	1
Introduction	2
High Priority Controls	3
SOE hardening.....	3
Authentication hardening.....	3
Application hardening.....	3
Application versions and patches.....	3
Application Whitelisting	3
Credential Caching	5
Credential Entry.....	6
Early Launch Antimalware.....	6
Elevating Privileges.....	6
Local Administrator Accounts.....	7
Microsoft Edge	7
Operating System Patching.....	8
Password Policy.....	8
Operating System Architecture.....	8
Secure Boot.....	8
Medium Priority Controls	8
Account Lockout Policy.....	8
Anonymous Connections	8
Audit Event Management	9
AutoPlay and AutoRun.....	11
BIOS and UEFI passwords	11
Bridging Networks.....	11
File and Print Sharing	11
Group Policy Processing.....	12
Hard Drive Encryption.....	12

Installing Applications	15
Internet Printing	16
Microsoft Accounts	16
Network Authentication	16
NoLMHash policy	16
Powershell	17
Remote Procedure Call	17
Reporting System Information	17
Safe Mode	17
Secure channel communications	18
Security Policies	18
Server Message Block sessions	19
Session Locking	19
Sound Recorder	20
System cryptography	20
Windows Remote Management	21
Windows Search and Cortana	21
Windows to Go	21
Boot Devices	22
Controls not currently implemented	22
Approval and Implementation	23
Review	23
Version Control	23

Introduction

This document details the security hardening implemented on APM's Standard Operating Environment (SOE). The standard has been based on the Australian Signals Directorate (ASD) *Hardening Microsoft Windows 10 version 21H1, Workstations* guide and is intended to be read in conjunction with it.

APM have chosen to assess the recommended High and Medium priority controls and implement them unless there is an impact to business operations by doing so. These controls are referenced by the section number in the ASD guide. Where APM have chosen not to implement, or vary from a control in the ASD guide, this has been noted in this standard.

High Priority Controls

SOE hardening

SOEs are reviewed and updated annually.

SOEs provided by third parties are scanned for malicious content and configurations before being used.

Authentication hardening

Passphrases used for single-factor authentication are a minimum of 20 characters with complexity, ideally as 6 random words.

Passphrases used for single-factor authentication cannot be used to authenticate to multiple different systems.

Service accounts are created as group Managed Service Accounts.

Application hardening

Application control is implemented on all workstations to restrict the execution of executables, software libraries, scripts, and installers to an approved set.

Application control is implemented using cryptographic hash rules, publisher certificate rules or path rules.

Cryptographic hash rules, publisher certificate rules and path rules used for application control are validated at least annually.

- When implementing application control using publisher certificate rules, both publisher names and product names are used.
- When implementing application control using path rules, file system permissions are configured to prevent unauthorised modification of folder and file permissions, folder contents (including adding new files) and individual files that are approved to execute.

Microsoft's latest recommended block rules are implemented to prevent application control bypasses.

All users (with the exception of privileged users when performing specific administrative activities) cannot disable, bypass or be exempted from application control.

Application control is configured to generate event logs for failed execution attempts, including the name of the blocked file, the date/time stamp and the username of the user attempting to execute the file.

Applications that allow the use of Macros such as Microsoft Office are configured in a way which disables all Macros with a notification to reduce the risk of untrusted Macros running and prevention of them running of their own accord.

Applications that are installed on to an SOE machine are required to have gone through the Software Approval process which validates the security posture of the vendor and config of the application.

Application versions and patches

SOE machines are scanned by Lansweeper to confirm versioning information of applications installed to ensure they are current. In addition, all SOE machines are to be onboarded to Intune and scanned by Defender for Endpoint to ensure they are patched and kept up to date.

Vulnerabilities are addressed in a timely manner depending on the severity of the security vulnerability.

Application Whitelisting

AppLocker has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting		Options
Computer Configuration\Policies\Windows Settings\Security Settings\Application Control Policies\AppLocker\ DLL Rules		
[Path] %ProgramFiles%*		Allow Everyone
[Path] %WinDir%*		Allow Everyone Exceptions: %System32%\spool\drivers\color\ %System32%\Tasks\ %WinDir%\Tasks\ %WinDir%\Temp\
Computer Configuration\Policies\Windows Settings\Security Settings\Application Control Policies\AppLocker\ Executable Rules		
[Path] %ProgramFiles%*		Allow Everyone
[Path] %WinDir%*		Allow Everyone Exceptions: %System32%\spool\drivers\color\ %System32%\Tasks\ %WinDir%\Tasks\ %WinDir%\Temp\
Computer Configuration\Policies\Windows Settings\Security Settings\Application Control Policies\AppLocker\ Packaged app Rules		
[Publisher] CN=Microsoft Corporation, O=Microsoft Corporation, L=Redmond, S=Washington, C=US		Allow Everyone
Computer Configuration\Policies\Windows Settings\Security Settings\Application Control Policies\AppLocker\ Script Rules		
[Path] %ProgramFiles%*		Allow Everyone
[Path] %WinDir%*		Allow Everyone Exceptions: %System32%\Com\dmp\ %System32%\FxsTmp\ %System32%\spool\drivers\color\ %System32%\spool\PRINTERS\ %System32%\spool\SERVERS\ %System32%\Tasks\ %WinDir%\Registration\CRMLog\ %WinDir%\Tasks\ %WinDir%\Temp\ %WinDir%\tracing\

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Application Control Policies\AppLocker\ Windows Installer Rules	
[Publisher] CN=Microsoft Corporation, O=Microsoft Corporation, L=Redmond, S=Washington, C=US	Allow Everyone

A full list of AppLocker exceptions can be found in the GPO 'Merge-Default Computer'.

Credential Caching

Credential Caching has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Interactive logon: Number of previous logons to cache (in case domain controller is not available)	2 logons***
Network access: Do not allow storage of passwords and credentials for network authentication	Enabled
Computer Configuration\Policies\Administrative Templates\MS Security Guide	
WDigest Authentication	Disabled
Computer Configuration\Policies\Administrative Templates\System\Device Guard	
Turn On Virtualization Based Security	Enabled*** Select Platform Security Level: Secure Boot Virtualization Based Protection of Code Integrity: Disabled Require UEFI Memory Attributes Table Disabled Credential Guard Configuration: Disabled

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

Credential Entry

Credential Entry has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\System\Logon	
Do not display network selection UI	Not enabled***
Enumerate local users on domain-joined computers	Disabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Credential User Interface	
Do not display the password reveal button	Enabled
Enumerate administrator accounts on elevation	Disabled
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Interactive logon: Do not require CTRL+ALT+DEL	Disabled
Interactive logon: Don't display username at sign-in	Not enabled***

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

Early Launch Antimalware

Early Launch Antimalware has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\System\Early Launch Antimalware	
Boot-Start Driver Initialization Policy	Enabled Choose the boot-start drivers that can be initialized: Good and unknown

Elevating Privileges

Elevating Privileges has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
User Account Control: Admin Approval Mode for the Built-in Administrator account	Enabled
User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop	Disabled
User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode	Prompt for credentials on the secure desktop

User Account Control: Behavior of the elevation prompt for standard users	Prompt for credentials on the secure desktop
User Account Control: Detect application installations and prompt for elevation	Enabled
User Account Control: Only elevate UIAccess applications that are installed in secure locations	Enabled
User Account Control: Run all administrators in Admin Approval Mode	Enabled
User Account Control: Switch to the secure desktop when prompting for elevation	Enabled
User Account Control: Virtualize file and registry write failures to per-user locations	Enabled

Local Administrator Accounts

Local administrator accounts are disabled.

Unique domain accounts with local administrative privileges, but without domain administrative privileges, are used for workstation and server management.

APM have implemented the Local Administrator Password Solution (LAPS) for management of workstation administrator account passwords.

UAC Restrictions has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\MS Security Guide	
Apply UAC restrictions to local accounts on network logons	Enabled

Microsoft Edge

Microsoft Edge has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Microsoft Edge	
Allow Adobe Flash	Not Disabled***
Allow Developer Tools	Not Disabled***
Configure Do Not Track	Enabled
Configure Password Manager	Disabled
Configure Pop-up Blocker	Enabled
Configure Windows Defender SmartScreen	Enabled

Prevent access to the about:flags page in Microsoft Edge	Enabled
Prevent bypassing Windows Defender SmartScreen prompts for files	Enabled
Prevent bypassing Windows Defender SmartScreen prompts for sites	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Defender SmartScreen\Microsoft Edge	
Configure Windows Defender SmartScreen	Enabled
Prevent bypassing Windows Defender SmartScreen prompts for sites	Enabled

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

Operating System Patching

Microsoft System Center Configuration Manager configures and manages the Windows Update settings, thus specific configuration is not required.

Password Policy

APM have set a password-policy domain-wide which is not specific to Windows 10. The policy settings exceed those specified in the ASD Guide.

Operating System Architecture

As per the ASD hardening guide APM's entire fleet is built on x64 system architecture. No machine images are based off an alternative.

Latest or N-1 version of OS is used.

Secure Boot

As per ASD hardening guide Secure Boot is set by the hardware vendor at the factory and is also applied as a step during the build process.

Medium Priority Controls

Account Lockout Policy

The account lockout policy is configured across the domain and is not specific to Windows 10. The lockout settings exceed those specified in the ASD guide.

Anonymous Connections

Anonymous Connections has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Network\Lanman Workstation	
Enable insecure guest logons	Disabled

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Network access: Allow anonymous SID/Name translation	Disabled
Network access: Do not allow anonymous enumeration of SAM accounts	Enabled
Network access: Do not allow anonymous enumeration of SAM accounts and shares	Enabled
Network access: Let Everyone permissions apply to anonymous users	Disabled
Network access: Restrict anonymous access to Named Pipes and Shares	Enabled
Network access: Restrict clients allowed to make remote calls to SAM	O:BAG:BAD:(A;;RC;;;BA)
Network security: Allow Local System to use computer identity for NTLM	Enabled
Network security: Allow LocalSystem NULL session fallback	Disabled
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment	
Access this computer from the network	Administrators Remote Desktop Users

Audit Event Management

Audit Event Management has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\System\Audit Process Creation	
Include command line in process creation events	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\Application	
Specify the maximum log file size (KB)	Enabled Maximum Log Size (KB): 65536
Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\Security	
Specify the maximum log file size (KB)	Enabled Maximum Log Size (KB): 2097152
Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\System	
Specify the maximum log file size (KB)	Enabled

Group Policy Setting	Options
	Maximum Log Size (KB): 65536
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment	
Manage auditing and security log	Administrators
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Management	
Audit Computer Account Management	Success and Failure
Audit Other Account Management Events	Success and Failure
Audit Security Group Management	Success and Failure
Audit User Account Management	Success and Failure
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Detailed Tracking	
Audit Process Creation	Success
Audit Process Termination	Success
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff	
Audit Account Lockout	Success and Failure***
Audit Logoff	Success
Audit Logon	Success and Failure
Audit Special Logon	Success
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access	
Audit Kernel Object	Success and Failure
Audit Other Object Access Events	Success and Failure
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change	
Audit Audit Policy Change	Success and Failure
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System	
Audit System Integrity	Success and Failure
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	

Group Policy Setting	Options
Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings	Enabled

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

AutoPlay and AutoRun

AutoPlay and AutoRun has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\AutoPlay Policies	
Disallow Autoplay for non-volume devices	Enabled
Set the default behavior for AutoRun	Enabled Default AutoRun Behavior: Do not execute any autorun commands
Turn off Autoplay	Enabled Turn off Autoplay on: All drives

BIOS and UEFI passwords

BIOS passwords are set by the hardware vendor at the factory, and Intune runs compliance checks to verify the password has been set.

Bridging Networks

Bridging Networks has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Network\Network Connections	
Prohibit installation and configuration of Network Bridge on your DNS domain network	Enabled
Route all traffic through the internal network	Not Enabled***
Computer Configuration\Policies\Administrative Templates\Network\Windows Connection Manager	
Prohibit connection to non-domain networks when connected to domain authenticated network	Enabled

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

File and Print Sharing

File and Print Sharing has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\HomeGroup	
Prevent the computer from joining a homegroup	Enabled

Group Policy Processing

Group Policy Processing has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Network\Network Provider	
Hardened UNC Paths	Enabled Hardened UNC Paths: *\SYSVOL RequireMutualAuthentication=1, RequireIntegrity=1 *\NETLOGON RequireMutualAuthentication=1, RequireIntegrity=1
Computer Configuration\Policies\Administrative Templates\System\Group Policy	
Configure registry policy processing	Enabled Process even if the Group Policy objects have not changed
Configure security policy processing	Enabled Process even if the group policy objects have not changed
Turn off background refresh of Group Policy	Disabled
Turn off Local Group Policy Objects processing	Not Enabled***

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

Hard Drive Encryption

Hard Drive Encryption has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\ Operating System Drives	
Choose how BitLocker-protected operating system drives can be recovered	Enabled Allow data recovery agent Configure user storage of BitLocker recovery information: Allow 48-digit recovery password Allow 256-bit recovery key

Group Policy Setting	Options
	Omit recovery options from the BitLocker setup wizard Save BitLocker recovery information to AD DS for operating system drives Configure storage of BitLocker recovery information to AD DS: Backup recovery passwords and key packages Do not enable BitLocker until recovery information is stored to AD DS for operating system drives
Disallow standard users from changing the PIN or password	Disabled
Require additional authentication at startup	Enabled Allow BitLocker without a compatible TPM (requires a password or a startup key on a USB flash drive) Settings for computers with a TPM Configure TPM startup: Do not allow TPM Configure TPM startup PIN: Allow startup PIN with TPM Configure TPM startup key: Allow startup key with TPM Configure TPM startup key and PIN: Allow startup key and PIN with TPM

In addition to the recommend options, the following MBAM options have been configured in GPO 'Merge-Default Computer':

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\MDOP MBAM (BitLocker Management)	
Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later)	Enabled Select the encryption method for operating system drives: XTS-AES 256-bit Select the encryption method for fixed data drives: XTS-AES 256-bit Select the encryption method for removable data drives: AES-CBC 256-bit
Choose drive encryption method and cipher strength.	Enabled AES 256-bit with Diffuser
Provide the unique identifiers for your organization	Enabled APM-Bitlocker
Computer Configuration\Policies\Administrative Templates\Windows Components\MDOP MBAM (BitLocker Management)\Client Management	

Group Policy Setting	Options
Configure customer experience improvement program	Disabled
Configure MBAM services	Enabled MBAM Recovery service endpoint: set Select BitLocker recovery information to store: Recovery password and key package Enter client checking status frequency in (minutes): 90 Configure MBAM Status reporting service: Disabled MBAM Status reporting service endpoint: Enter status report frequency in (minutes): 720
Computer Configuration\Policies\Administrative Templates\Windows Components\MDOP MBAM (BitLocker Management)\Fixed Drive	
Encryption Policy Enforcement Settings	Enabled Configure the number of noncompliance grace period days for fixed drives. This grace period begins only after the operating system drive compliance is detected: 0
Fixed data drive encryption settings	Enabled This policy setting allows you to manage whether the fixed data drive must be encrypted or not. Configure Auto-Unlock for fixed data drive: Allow Auto-Unlock
Computer Configuration\Policies\Administrative Templates\Windows Components\MDOP MBAM (BitLocker Management)\Operating System Drive	
Encryption Policy Enforcement Settings	Enabled Configure the number of noncompliance grace period days for operating system drives: 0
Operating system drive encryption settings	Enabled Allow BitLocker without a compatible TPM (requires a password) Disabled Select protector for operating system drive: Settings for computers with a TPM: Configure minimum PIN length for startup 4
Computer Configuration\Policies\Administrative Templates\Windows Components\MDOP MBAM (BitLocker Management)\Removable Drive	

Group Policy Setting	Options
Allow access to BitLocker-protected removable data drives from earlier versions of Windows	Disabled
Configure use of passwords for removable data drives	Enabled Require password for removable data drive Enabled Configure password complexity for removable data drives: Require password complexity Minimum password length for removable data drive: 10 Note: You must enable the "Password must meet complexity requirements" policy setting for the password complexity setting to take effect.
Control use of BitLocker on removable drives	Enabled When enabling BitLocker on a removable drive, see explanation for policies setting on system/removable storage access Allow users to apply BitLocker protection on removable data drives Enabled Allow users to suspend and decrypt BitLocker protection on removable data drives Enabled
Deny write access to removable drives not protected by BitLocker	Enabled Deny write access to devices configured in another organization Disabled

Installing Applications

Installing Applications has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Installer	
Allow user control over installs	Disabled
Always install with elevated privileges	Disabled
User Configuration\Policies\Administrative Templates\Windows Components\Windows Installer	
Always install with elevated privileges	Disabled

Internet Printing

Internet Printing has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings	
Turn off downloading of print drivers over HTTP	Enabled
Turn off printing over HTTP	Enabled

Microsoft Accounts

Microsoft Accounts have been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Microsoft account	
Block all consumer Microsoft account user authentication	Enabled
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Accounts: Block Microsoft accounts	Users can't add or log on with Microsoft accounts

Network Authentication

Network Authentication has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Network security: Configure encryption types allowed for Kerberos	AES128_HMAC_SHA1 AES256_HMAC_SHA1
Network security: LAN Manager authentication level	Send NTLMv2 response only. Refuse LM & NTLM
Network security: Minimum session security for NTLM SSP based (including secure RPC) clients	Require NTLMv2 session security Require 128-bit encryption
Network security: Minimum session security for NTLM SSP based (including secure RPC) servers	Require NTLMv2 session security Require 128-bit encryption

NoLMHash policy

NoLMHash Policy has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Network security: Do not store LAN Manager hash value on next password change	Enabled

Powershell

PowerShell is configured to use module logging, script block logging and transcription functionality.

PowerShell script block logs are protected by Protected Event Logging functionality.

Remote Procedure Call

Remote Procedure Call has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\System\Remote Procedure Call	
Restrict Unauthenticated RPC clients	Enabled RPC Runtime Unauthenticated Client Restriction to Apply: Authenticated

Reporting System Information

Reporting System Information has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\System\Troubleshooting and Diagnostics\Microsoft Support Diagnostic Tool	
Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider	Disabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Application Compatibility	
Turn off Inventory Collector	Enabled
Turn off Steps Recorder	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Data Collection and Preview Builds	
Allow Telemetry	Enabled 0 - Security [Enterprise Only] **

Safe Mode

Non-administrators are restricted from using Safe Mode as this is locked down and requires the computer's BitLocker code to progress.

Secure channel communications

Secure Channel Communications has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Domain member: Digitally encrypt or sign secure channel data (always)	Enabled
Domain member: Digitally encrypt secure channel data (when possible)	Enabled
Domain member: Digitally sign secure channel data (when possible)	Enabled
Domain member: Require strong (Windows 2000 or later) session key	Enabled

Security Policies

Security Policies have been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Cloud Content	
Turn off Microsoft consumer experiences	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\File Explorer	
Turn off heap termination on corruption	Disable
Turn off shell protocol protected mode	Disable
Computer Configuration\Policies\Administrative Templates\Windows Components\RSS Feeds	
Prevent downloading of enclosures	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Search	
Allow indexing of encrypted files	Disable
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Game Recording and Broadcasting	
Enables or disables Windows Game Recording and Broadcasting	Disable
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Domain member: Disable machine account password changes	Disable
Domain member: Maximum machine account password age	30 Days
Network security: Force logoff when logon hours expire	Enabled
Network security: LDAP client signing requirements	Negotiate signing

Group Policy Setting	Options
System objects: Require case insensitivity for non-Windows subsystems	Enabled
System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)	Enabled

Server Message Block sessions

Server Message Block sessions has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	
Microsoft network client: Digitally sign communications (always)	Enabled
Microsoft network client: Digitally sign communications (if server agrees)	Enabled
Microsoft network client: Send unencrypted password to third-party SMB servers	Disabled
Microsoft network server: Amount of idle time required before suspending session	15 Minutes
Microsoft network server: Digitally sign communications (always)	Enabled
Microsoft network server: Digitally sign communications (if client agrees)	Enabled
Computer Configuration\Policies\Administrative Templates\MS Security Guide	
Configure SMB v1 client driver	Enabled Configure MrxSmb10 driver: Disable driver (recommended)
Configure SMB v1 server	Disabled

Session Locking

Some Session Locking settings have been defined across APM's environment which are not specific to Windows 10. In addition to these, the following have been implemented as per GPO 'Merge-Default Computer' and 'Merge-Windows Screen Settings' which contain:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Control Panel\Personalization	
Prevent enabling lock screen camera	Enabled
Prevent enabling lock screen slide show	Enabled

Computer Configuration\Policies\Administrative Templates\System\Login	
Allow users to select when a password is required when resuming from connected standby	Disabled
Turn off App Notifications on the lock screen	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\File Explorer	
Show lock in the user tile menu	Enabled
User Configuration\Policies\Administrative Templates\Control Panel\Personalization	
Enable screen saver	Enabled
Password protect the screen saver	Enabled
Screen saver timeout	Enabled Seconds: 480
User Configuration\Policies\Administrative Templates\Start Menu and Taskbar\Notifications	
Turn off toast notifications on the lock screen	Enabled
User Configuration\Policies\Administrative Templates\Windows Components\Cloud Content	
Do not suggest third-party content in Windows spotlight	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Ink Workspace	
Allow Windows Ink Workspace	Enabled Choose one of the following actions: On, but disallow access above lock

Sound Recorder

Sound Recorder has been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Sound Recorder	
Do not allow Sound Recorder to run	Enabled

System cryptography

Strong key protection has been configured as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options	

Group Policy Setting	Options
System cryptography: Force strong key protection for user keys stored on the computer	User must enter a password each time they use a key
System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing	Not Enabled***

***These settings are a divergence from the ASD Hardening guide as determined to be appropriate by APM.

Windows Remote Management

Windows Remote Management been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client	
Allow Basic authentication	Disabled
Allow unencrypted traffic	Disabled
Disallow Digest authentication	Enabled
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service	
Allow Basic authentication	Disabled
Allow unencrypted traffic	Disabled
Disallow WinRM from storing RunAs credentials	Enabled

Windows Search and Cortana

Search and Cortana have been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Search	
Allow Cortana	Disabled
Don't search the web or display web results in Search	Enabled

Windows to Go

Startup options for Windows to Go have been implemented as per GPO 'Merge-Default Computer' which contains:

Group Policy Setting	Options
Computer Configuration\Policies\Administrative Templates\Windows Components\Portable Operating System	

Windows To Go Default Startup Options

Disabled

Boot Devices

As per the ASD recommendation access to booting from an alternative device other than the primary drive is prohibited with administrative access set by the hardware vendor at the factory and is also validated as a step during the build process.

Controls not currently implemented

Group Policy Setting	Options	Justification	Date of Acceptance	Risk accepted by	Next review date
Computer Configuration\Policies\Administrative Templates\Windows Components\OneDrive	Prevent the usage of OneDrive for file storage - Enabled	One Drive is used throughout the organisation for storage/backup of files			
User Account Control: Behaviour of the elevation prompt for standard users	Automatically deny elevation requests	This would remove Service Desk's ability to achieve administrator elevation when attempting to troubleshoot/resolve issues on staff devices.			
Computer Configuration\Policies\Administrative Templates\Windows Components\Data Collection and Preview Builds	Allow Telemetry – Enabled – 0 – Security [Enterprise Only]. Setting is currently set to 3.	Setting unable to be adjusted to the recommended 0 due to telemetry being required for Windows Update for Business.			
Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Error Reporting\Advanced Error Reporting Settings	Configure Corporate Windows Error Reporting – Enabled - Corporate server name: <organisation defined>	We don't have a corporate Windows Error reporting server and as with the above telemetry control, unable to be implemented as will impact Windows Update for Business which is still in use.			

	Connect using SSL				
	Server port: <organisation defined>				

Approval and Implementation

Content Expert:	End User Computer Manager
Responsible Executive Team Member:	ANZ Chief Information Officer
Approval:	Head of Digital Operations
Approval Date:	24/08/2023
Effective From:	24/08/2023

Review

Update this document whenever requirements change and review at least every year.

Version Control

Version	Date	Prepared by	Comments
0.1	27/09/2019	IT Operations Manager	
1.0	11/08/2021	IT Business Analyst	Added controls according to ISO 27001 and ASD ISM to harden APM's staff SOE
1.1	20/08/2023	IT End-User Computing Engineer	Added Controls for SOE Hardening Win 10 21H1. Minor changes to wording to reflect changes in systems.
1.2	14/07/2025	IT Infrastructure & Accreditation Manager	Reviewed and titles updates.